

Risk Assessment Process

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Purpose

Defines a lightweight, recurring process for identifying and tracking security/privacy risk as Penny Pilot grows — sized for a solo team today, built to scale into something more formal without starting over.

When a risk assessment happens

- At minimum **annually**.
- Before any **material architecture change**: e.g., moving the default data source from [mock](#) to [supabase](#) for real users, requesting Plaid production access (vs. Sandbox), adding a new vendor (see [Vendor Risk Management](#)), or introducing AI-based categorization (currently only a planned item per [docs/technical-architecture.md](#)).
- Before **onboarding the first real user** onto production Plaid credentials.
- Whenever team size changes (see [Employee Offboarding](#) for the departure side; growing the team triggers a review of every policy in this folder for what's still solo-operator-only language and needs a named second owner).
- After any security incident (as a required step in the [Incident Response Plan](#)).

Process

1. **List what changed** since the last assessment (new feature, new vendor, new data collected, new team member).
2. **Identify what's now at risk** — walk the data map in [Data Classification & Handling](#) and ask whether the change touches Restricted or Confidential-tier data, and whether existing controls ([Access Control](#), [Encryption](#)) still cover it.
3. **Rate each identified risk** informally as Low / Medium / High on likelihood and impact. A one-person team doesn't need a scoring rubric with decimal weights — the goal is to force a plain-language judgment call, not theater.
4. **Record it** in a running risk register (a simple table; can live as an appendix to this file or a separate tracked list once there's enough volume to warrant it):

Date identified	Risk	Likelihood	Impact	Mitigation	Owner	Target date	Status
2026-07-05	Dependabot alerts not enabled on the repo	Medium	Medium	Enable Dependabot alerts	Mark Stolte	2026-07-12	Closed — enabled 2026-07-05
2026-07-05	Single point of failure: founder holds all vendor account access, no documented recovery path	Low	High	Establish a secure credential-recovery record with a trusted contact	Mark Stolte	Before first production Plaid user	Open
2026-07-05	No confirmed Supabase backup/PITR window documented	Medium	Medium	Confirm plan-tier backup settings and document them	Mark Stolte	Before first production Plaid user	Open
2026-07-05	MFA not confirmed enabled on GitHub/Supabase/Plaid/Google admin dashboards (surfaced by Plaid vendor questionnaire Q4)	Medium	High	Enable MFA on all four admin accounts	Mark Stolte	2026-07-12	Open

2026-07-05	No endpoint protection/disk encryption confirmed on development machine (Plaid questionnaire Q7)	Low	Medium	Enable FileVault and confirm automatic OS security updates	Mark Stolte	2026-07-12	Open
2026-07-05	No published SECURITY.md ; GitHub private vulnerability reporting not enabled (API returned 404, possibly plan-gated for a private repo)	Low	Medium	Publish .github/SECURITY.md ; check Settings → Security → Private vulnerability reporting manually	Mark Stolte	2026-07-12	Partially closed — SECURITY.md published 2026-07-05; private vulnerability reporting still needs manual check
2026-07-05	No published privacy policy or in-app consent step (Plaid questionnaire Q8/Q9)	High	High	Draft and publish a privacy policy; add an in-app consent step	Mark Stolte	Before Plaid Link is used with real consumer accounts	Open

2026-07-05	Account deletion doesn't call Plaid <code>/item/remove</code> ; no law-specific retention schedule or self-service export/delete flow (Plaid questionnaire Q10)	Medium	High	Wire <code>/item/remove</code> into account deletion; write a retention schedule; add a data export/delete request path	Mark Stolte	Before Plaid Link is used with real consumer accounts	Open
------------	---	--------	------	---	-------------	---	------

5. **Decide:** fix now, schedule for later with a target date, or explicitly accept the risk with a documented reason (per [Information Security Policy](#)).

6. **Review previously recorded risks** for whether they're closed, still open, or need a new target date.

What this process is not

This is not a formal enterprise risk-management framework (no FAIR/ISO 27005 quantitative modeling, no cross-functional risk committee) — that level of process doesn't fit a one-person team and pretending otherwise would make this document less credible, not more. It is a recurring, written habit of asking "what changed, and what does that put at risk," which is the part that actually needs to happen regardless of team size.

Escalation as the team grows

Once Penny Pilot has more than one person with system access, this process gains a second required participant (not just the founder) for any risk rated High impact, so no single person's blind spot goes unreviewed.